

Junior Cloud Security Engineer

Internship Task Report

1.0 Task Overview

Task ID	CSE-AWS-L-007-04
Task Title	IAM Enumeration, Visibility Analysis, and Access Mapping
Skill Domain	AWS Identity and Access Management (IAM) Security
Difficulty	Advanced
Duration	14 Hours
CPE Credits	4 CPE Credits
Cloud Platform(s)	AWS Free Tier
AWS Region(s) Used	us-east-2
Primary Tools	AWS CLI, CloudGoat, IAM Access Analyzer, Policy Sentry, Steampipe, ChatGPT or Claude for AI-assisted analysis
Target Environment	CloudGoat IAM-focused scenarios, PwnedLabs (Free Lab1), Cybr (Free Lab2)
MITRE ATT&CK IDs	T1078 (Valid Accounts), T1530 (Data from Cloud Storage Object), T1098 (Account Manipulation)
Guiding Frameworks	CIS AWS Foundations Benchmark v1.5, NIST SP 800-53, ISO 27001, OWASP Cloud Top 10
Regulatory Alignment	ISO 27001 A.9 Access Control, A.12 Operations Security; NICE PR-CDA-001; SFIA Level 3-4

1.1 Introduction

This project focuses on AWS IAM enumeration and identifying security risks caused by excessive or misconfigured permissions. It demonstrates how cloud security engineers can analyze users, roles, policies, and trust relationships to identify privilege-escalation risks and improve access security.

1.2 Objectives & Learning Outcomes

Objective 1 – Understand IAM enumeration fundamentals and how attackers exploit IAM misconfigurations.

I met this objective by studying the relationships between AWS IAM users, roles, policies, permissions, and trust policies and by using AWS CLI commands such as `list-users`, `list-roles`, and `list-policies` to understand how IAM information can be enumerated.

Objective 2 – Deploy and examine a controlled IAM security environment using CloudGoat.

I met this objective by configuring CloudGoat and Terraform and deploying the `iam_privesc_by_attachment` scenario in a controlled AWS lab environment. The deployed environment provided IAM resources for practicing enumeration and privilege-escalation analysis.

Objective 3 – Enumerate AWS identities and analyze their permissions and trust relationships.

I met this objective by enumerating IAM users, groups, customer-managed policies, and roles using the AWS CLI. I also examined role trust policies through `AssumeRolePolicyDocument` and analyzed the `privesc9-AttachRolePolicy` policy, which permitted `iam:AttachRolePolicy` against "Resource": "*".

Objective 4 – Assess IAM visibility gaps and translate technical findings into business risk.

I met this objective by enabling IAM Access Analyzer in `us-east-2`, confirming that the account-level analyzer was active, and reviewing its findings. Access Analyzer returned no external or cross-account findings at the time of testing. I then created a risk matrix assessing privilege escalation, wildcard permission scope, and IAM governance risks according to likelihood, impact, and recommended mitigation.

Objective 5 – Reinforce IAM security knowledge through practical hosted labs and professional reporting.

I met this objective by using the Phase E hosted-lab exercises to reinforce AWS credential-abuse detection and IAM credential-report concepts. The technical evidence and findings from the project were then organized for reporting with risk-based recommendations and alignment to access-control principles.

1.2 Scope & Legal Authorisation

All activities were performed only within authorised training and lab environments. No production systems, customer data, or unauthorised third-party resources were accessed.

Authorised environments used:

- AWS lab account — `us-east-2` region
- CloudGoat — `iam_privesc_by_attachment` scenario
- PwnedLabs — authorised AWS security training environment
- Cybr IAM Lab — authorised training environment

ChatGPT was used only for guidance, analysis, troubleshooting, and documentation. All AWS commands and technical activities were performed manually within the authorised lab environments.

1.3 MITRE ATT&CK Cloud Threat Mapping

MITRE ATT&CK Technique ID	Technique Name	Relevance to This Task
T1087.004	Account Discovery: Cloud Account	IAM enumeration was performed to identify AWS users, roles, groups, and other identities available in the cloud environment.
T1098	Account Manipulation	The CloudGoat scenario demonstrated how excessive IAM permissions, such as iam:AttachRolePolicy, can be abused to modify privileges and create a privilege-escalation path.
T1078.004	Valid Accounts: Cloud Accounts	The project examined how valid AWS IAM credentials and identities can be used to access cloud resources and enumerate permissions.

2.0 Environment & Tool Setup

2.1 Cloud Architecture Overview

The lab environment was hosted in AWS and focused primarily on IAM enumeration, permission analysis, privilege-escalation testing, and access visibility. CloudGoat provided the controlled vulnerable IAM scenario, while AWS CLI and supporting security tools were used for enumeration and analysis.

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
AWS IAM Users	AWS IAM	Identities used for enumeration and permission analysis	AWS account lab environment
AWS IAM Roles	AWS IAM	Used to analyze role permissions, trust relationships, and privilege-escalation paths	AWS account lab environment
IAM Policies	AWS IAM	Reviewed permissions such as iam:AttachRolePolicy and wildcard resource access	Customer-managed and lab policies
IAM Access Analyzer	AWS Access Analyzer	Checked for external access and cross-account trust findings	us-east-2 / Account analyzer / Active
CloudGoat	Security Lab / Terraform	Deployed the vulnerable iam_privesc_by_attachment scenario	Controlled AWS lab
AWS CLI	Command-line tool	Enumerated users, groups, roles, policies, and trust relationships	Configured with AWS lab account

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
Policy Sentry	IAM Analysis Tool	Used/attempted for IAM policy analysis	Local/CloudShell tool
Steampipe	Cloud Query Tool	Attempted SQL-based IAM role enumeration; AWS CLI used as fallback due to embedded PostgreSQL error	AWS CloudShell

2.2 AWS CLI & Tool Configuration

Tool / Service	Version	Installation Method	Purpose in This Task
AWS CLI	AWS CLI v2	Available/configured in AWS environment	IAM enumeration, querying users, roles, policies, trust relationships, and Access Analyzer
CloudGoat	CloudGoat 2.x	Python/pip installation from CloudGoat project	Deployed the iam_privesc_by_attachment vulnerable IAM scenario
Terraform	Installed CLI version	Installed in the AWS lab environment	Provisioned infrastructure required by the CloudGoat scenario
Steampipe	v2.4.5	Installed through Steampipe installer with AWS plugin	Attempted SQL-based IAM role enumeration; embedded PostgreSQL installation failed, so AWS CLI was used as fallback
Policy Sentry	Installed Python version	Installed using pip	IAM policy analysis; the specified analyze command was unavailable in the installed version, so the exported policy was manually analyzed
IAM Access Analyzer	AWS Managed	Enabled using AWS CLI/AWS service	Identified potential external and cross-account access; account analyzer was active in us-east-2

Key Configuration Commands Used

AWS identity verification

```
aws sts get-caller-identity
```

Output:

```
Account: 938500344456
```

```
ARN: arn:aws:iam::938500344456:root
```

AWS region verification

aws configure get region
us-east-2

CloudGoat configuration

cloudgoat config aws

Verify CloudGoat installation

cloudgoat --help

Verify Terraform installation

terraform version

Verify deployed CloudGoat scenario

cloudgoat list deployed

Output:

Deployed scenario instances: 1

iam_privesc_by_attachment
CGID: cgid81ra5fh8i7

Verify IAM Access Analyzer configuration

aws accessanalyzer list-analyzers \

--query 'analyzers[*].[name,type,status]' \

--output table

Output:

PhaseD-AccessAnalyzer ACCOUNT ACTIVE

2.3 AI Tool Usage Declaration

AI Tool	Used For	What Was NOT Done with AI
ChatGPT	Explaining AWS IAM concepts, troubleshooting tool errors, interpreting IAM policy permissions, summarising risks, and assisting with report documentation.	AI did not execute AWS CLI commands, access the AWS environment, generate CLI evidence/screenshots, or perform the lab activities.

Declaration:

All AWS CLI commands, configurations, lab execution, screenshots, and technical evidence were performed and collected manually within the authorised lab environment. ChatGPT was used only for guidance, explanation, analysis, troubleshooting, and documentation assistance.

3.0 Methodology — Phase Execution

Phase A: Understand IAM enumeration fundamentals and how attackers exploit misconfigurations.

Phase Objective	Understand IAM enumeration fundamentals and how attackers exploit misconfigurations.
Estimated Time	60 minutes
Evidence File(s)	PhaseA-List -Users.png, PhaseA-List -Roles.png, PhaseA-List -Policies.png, phaseA_summary.txt

Actions Taken

I reviewed the fundamentals of AWS Identity and Access Management (IAM), focusing on how users, roles, managed policies, inline policies, and role trust policies interact. I studied how IAM enumeration can reveal available identities and permissions that may lead to privilege-escalation opportunities.

The following AWS CLI commands were used to examine the IAM environment:

```
aws iam list-users
```

```
aws iam list-policies
```

```
aws iam list-roles
```

```
aws iam list-attached-user-policies --user-name <username>
```

```
aws iam get-role --role-name <role-name>
```

The results were reviewed to understand how an attacker with valid AWS credentials could enumerate IAM resources and identify potentially privileged identities.

ChatGPT was used to explain **explicit vs. implicit permissions in AWS**. Explicit permissions are permissions directly allowed or denied through IAM policies, while implicit denial applies when no policy grants the requested action. An explicit Deny overrides an Allow.

Key Observations

IAM enumeration provides significant information about an AWS environment even before any privilege-escalation activity occurs. Users, roles, attached policies, and trust relationships can reveal how access is structured and where excessive permissions may exist.

The phase also demonstrated that IAM security depends on both permission policies and trust relationships. Excessive permissions, wildcard resources, or overly permissive role trust can increase the risk of unauthorized access and privilege escalation.

The activity relates particularly to MITRE ATT&CK T1087.004 – Account Discovery: Cloud **Account**, because IAM identities were enumerated to understand the available cloud accounts and roles.

Evidence Produced

- **PhaseA-List -Users.png** — Screenshot showing IAM users identified through AWS CLI enumeration.
- **PhaseA-List -Roles.png** — Screenshot showing IAM roles and role information.

- **PhaseA-List -Policies.png** — Screenshot showing IAM policy enumeration/attached policy information.
- **phaseA_summary.txt** — Short written summary of IAM enumeration concepts, explicit versus implicit permissions, and key observations.

Phase B: Deploy a controlled environment using CloudGoat's IAM scenario.

Phase Objective	Deploy a controlled environment using CloudGoat's IAM scenario.
Estimated Time	90 minutes
Evidence File(s)	PhaseB-CloudGoat-Deployed.png, PhaseB-IAM-Users.png, PhaseB-IAM-Roles.png, PhaseB_iam_entities.csv

Actions Taken

I configured and deployed a controlled AWS IAM lab environment using **CloudGoat** and **Terraform**. The `iam_privesc_by_attachment` scenario was used to provide an intentionally vulnerable environment for IAM enumeration and privilege-escalation analysis.

Key commands included:

```
cloudgoat config aws
```

```
cloudgoat create iam_privesc_by_attachment
```

```
cloudgoat list deployed
```

The deployment was verified as:

```
iam_privesc_by_attachment
```

```
CGID: cgid81ra5fh8i7
```

IAM users and roles were then enumerated to document the identities available in the lab environment:

```
aws iam list-users
```

```
aws iam list-roles
```

Key Observations

CloudGoat demonstrated how intentionally vulnerable IAM configurations can be safely deployed for security testing. The environment provided IAM users, roles, and policies that could be examined for excessive permissions and potential privilege-escalation paths.

This phase also demonstrated the importance of maintaining a clear inventory of cloud identities. Knowing which users and roles exist is necessary before their permissions, trust relationships, and associated risks can be properly assessed.

Evidence Produced

- **PhaseB-CloudGoat-Deployed.png** — Shows the deployed `iam_privesc_by_attachment` CloudGoat scenario.

- **PhaseB-IAM-Users.png** — Shows IAM users enumerated in the AWS lab environment.
- **PhaseB-IAM-Roles.png** — Shows IAM roles identified during environment verification.
- **PhaseB_iam_entities.csv** — Inventory of IAM entities documented for the lab.

Phase C: Enumerate all identities and map their permissions manually and programmatically.

Phase Objective	Enumerate all identities and map their permissions manually and programmatically.
Estimated Time	180 minutes
Evidence File(s)	PhaseC-IAM-Users.png PhaseC-IAM-Groups.png PhaseC-IAM-Policies.png PhaseC-Role-Trust-Policy.png. PhaseC-Sidekick-Error.png PhaseC_policies.json PhaseC_analysis.txt

Actions Taken

I performed detailed IAM enumeration to identify AWS users, groups, policies, and roles and analyze their permissions. AWS CLI was used as the primary enumeration method.

Key commands included:

```
aws iam list-users
```

```
aws iam list-groups
```

```
aws iam list-policies --scope Local
```

```
aws iam list-roles
```

Sidekick was also configured for SQL-based IAM enumeration:

```
sidekick query "select name, arn from aws_iam_role;"
```

However, the query could not run because its embedded PostgreSQL database failed to install in the CloudShell environment. AWS CLI role enumeration was therefore used as the alternative.

Role trust relationships were examined using:

```
aws iam get-role \  
  
--role-name <role-name> \  

```

```
--query 'Role.AssumeRolePolicyDocument'
```

The privesc9-AttachRolePolicy managed policy was also exported and reviewed. It contained:

```
{  
  "Action": "iam:AttachRolePolicy",  
  "Effect": "Allow",  
  "Resource": "*" }  
}
```

Policy Sentry analysis was attempted, but the installed version did not support the specified analyze command. The policy was therefore manually reviewed and the findings documented in analysis.txt.

Key Observations

IAM enumeration identified multiple roles associated with privilege-escalation testing. The most significant reviewed permission was iam:AttachRolePolicy with "Resource": "*", which allows policy attachment without restricting the action to a specific role.

This represents a potential privilege-escalation risk because excessive policy-attachment permissions could allow an identity to increase the privileges associated with an IAM role. The finding demonstrated the importance of **least privilege, restricted resource scope, and regular IAM permission reviews**.

Evidence Produced

- **PhaseC-IAM-Users.png** — IAM users identified during enumeration.
- **PhaseC-IAM-Groups.png** — IAM group enumeration results.
- **PhaseC-IAM-Policies.png** — Customer-managed IAM policies identified in the account.
- **PhaseC-Role-Trust-Policy.png** — Role trust relationship/AssumeRolePolicyDocument analysis.
- **PhaseC-Steampipe-Error.png** — Documents the Steampipe embedded PostgreSQL compatibility issue.
- **PhaseC_policies.json** — Exported privesc9-AttachRolePolicy policy document used for analysis.
- **PhaseC_analysis.txt** — Final IAM permission analysis and security findings required for Phase C.

Phase D: Perform visibility gap analysis and create a risk matrix linking misconfigurations to business assets.

Phase Objective	Perform visibility gap analysis and create a risk matrix linking misconfigurations to business assets.
Estimated Time	150 minutes
Evidence File(s)	PhaseD_risk_matrix.xlsx, PhaseD-AccessAnalyzer-Findings.png

Actions Taken

I performed an IAM visibility and risk assessment using **AWS IAM Access Analyzer**. An account-level analyzer was enabled in the us-east-2 region and verified as active.

Key commands included:

```
aws configure get region
```

```
aws accessanalyzer list-analyzers \  
--query 'analyzers[*].[name,type,status,arn]' \  
--output table
```

The analyzer was confirmed as:

Analyzer: PhaseD-AccessAnalyzer

Type: ACCOUNT

Status: ACTIVE

Region: us-east-2

I then reviewed the environment for external or cross-account access:

```
aws accessanalyzer list-findings \  
--analyzer-arn <analyzer-arn> \  
--output table
```

Key Observations

IAM Access Analyzer provided additional visibility into potential external and cross-account access. Although no Access Analyzer findings were returned, this did not eliminate risks associated with excessive internal IAM permissions.

The main risks identified were the ability to use `iam:AttachRolePolicy` broadly, wildcard (*) resource scope, and the need for stronger privileged-role governance. The analysis showed that Access Analyzer should be combined with IAM policy and trust-policy reviews to provide more complete visibility.

Evidence Produced

- **PhaseD-AccessAnalyzer-Findings.png** — Shows the Access Analyzer findings review, which returned no external/cross-account findings.
- **PhaseD_risk_matrix.xlsx** — Documents identified IAM risks, affected business assets, likelihood, impact, risk ratings, business impact, and recommended mitigations.

Risk Matrix (Phase D Output)

A	B	C	D	E	F	G	H	I	J
Phase D – Visibility & Risk Analysis									
Risk matrix based on verified Phase C IAM findings and Phase D IAM Access Analyzer results (us-east-2).									
Risk ID	Risk / Misconfiguration	Business Asset	Evidence / Finding	Likelihood	Impact	Risk Score	Risk Level	Business Impact	Recommended Mitigation
R-01	IAM policy attachment privilege escalation	IAM Roles / AWS Workloads	privesc9-AttachRolePolicy allows iam:AttachRolePolicy with Resource "".	5	5	25	Critical	A compromised identity with this capability could increase role privileges and expose sensitive workloads.	Restrict iam:AttachRolePolicy to approved role AF and approved managed policies; enforce least privilege.
R-02	Wildcard resource scope in IAM authorization	IAM Authorization / Privileged Roles	The analyzed policy applies iam:AttachRolePolicy to all resources using Resource "".	4	5	20	Critical	Broad scope increases the blast radius of credential compromise or configuration error.	Replace wildcard scope with specific role resource use permission boundaries and monitor sensitive I changes.
R-03	IAM visibility and privileged-role governance gap	IAM Roles / Identity Governance	Manual enumeration identified numerous privilege-escalation test roles. Access Analyzer is ACTIVE and returned zero external/cross-account findings.	3	4	12	High	No external-access finding does not eliminate internal excessive-permission risk.	Perform recurring IAM reviews, remove unused lab roles, review trust policies, and monitor privileged I actions.
Risk Scoring Guide				Phase D Access Analyzer Result					
Score Range	Level	Likelihood Scale	Impact Scale		Region	Analyzer	Type	Status	Findings
20–25	Critical	5 = Almost Certain	5 = Severe		us-east-2	PhaseD-AccessAnalyzer	ACCOUNT	ACTIVE	
12–19	High	4 = Likely	4 = Major		Interpretation review.	No external/cross-account findings were returned at the time of			
6–11	Medium	3 = Possible	3 = Moderate						
1–5	Low	1–2 = Unlikely	1–2 = Minor						
Executive Summary – Top Three Risks									
1. Privilege									

Phase E: Reinforce learning through guided external labs.

Phase Objective	Reinforce learning through guided external labs.
Estimated Time	240 minutes
Evidence File(s)	PhaseE_Cybr_Labs.png

Actions Taken

I reinforced the IAM concepts from the previous phases through guided AWS security labs. The hosted exercises focused on **IAM credential reporting** through Cybr. These activities provided additional practical exposure to identifying credential-related risks and reviewing IAM account security information in controlled training environments.

Key Observations:

The hosted labs demonstrated that compromised or poorly managed AWS credentials can create significant security risks. IAM credential reports can help identify security issues such as inactive credentials, password usage, and access-key status, while monitoring authentication and credential activity is important for detecting potential account misuse.

Evidence Produced

PhaseE_Cybr_Labs.png — Completion evidence for the Cybr *Generate IAM Credentials Reports* lab.

Phase F: Compile all findings into a professional report aligned with ISO/IEC 27001 A.9 controls.

Phase Objective	Compile all findings into a professional report aligned with ISO/IEC 27001 A.9 controls.
Estimated Time	120 Minutes
Evidence File(s)	CSE_CSE-AWS-L-007-04_S.K_20260819.pdf

Actions Taken

I consolidated the findings and evidence from Phases A–E into a professional IAM security assessment report. The report documents the AWS lab environment, IAM enumeration methodology, policy and trust relationship analysis, Access Analyzer results, risk ratings, MITRE ATT&CK mappings, and recommended security improvements.

The findings were also considered against **ISO/IEC 27001 access-control principles**, particularly the need for controlled identity access, appropriate authentication, least privilege, and regular review of access rights.

Key Observations

The overall assessment showed that IAM risk is not limited to external access. Although IAM Access Analyzer returned no external or cross-account findings, the manual policy assessment identified internal risks such as iam:AttachRolePolicy with unrestricted Resource: "*". This demonstrates the importance of combining automated visibility tools with manual IAM permission and trust-policy reviews.

Evidence Produced:

CSE_CSE-AWS-L-007-04_S.K_20260819.pdf - Final professional report

4.0 Findings

4.1 Findings Summary

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
1	Unrestricted IAM Policy Attachment Permission	Privilege Escalation Path / Access Control Weakness	AWS IAM / privesc9-AttachRolePolicy	T1098	Phase C	Critical	policies.json / analysis.txt
2	Wildcard Resource Scope in IAM Policy	IAM Policy Gap / Excessive Permission	AWS IAM Roles / Resource: "*"	T1098	Phase C/D	Critical	analysis.txt / risk_matrix.xlsx
3	Privileged IAM Role Governance Gap	Access Control / IAM Governance Gap	AWS IAM Roles / Identity Governance	T1087.004	Phase D	High	risk_matrix.xlsx / Access Analyzer screenshot

4.2 Detailed Finding Analysis

Finding 1: Unrestricted IAM Policy Attachment Permission

Field	Content
Finding Title	Unrestricted IAM Policy Attachment Permission
Type / Category	Privilege Escalation Path / Access Control Weakness
Cloud Service / Resource	AWS IAM – privesc9-AttachRolePolicy
Description	The reviewed IAM managed policy allowed the iam:AttachRolePolicy action with "Resource": "*". This gives broad permission to attach managed policies to IAM roles rather than restricting the action to specifically approved roles.
How Identified	The policy was identified through AWS CLI IAM enumeration. aws iam list-attached-role-policies identified the managed policy, and aws iam get-policy-version was used to export and review its permission document in policies.json.
MITRE ATT&CK Reference	T1098 – Account Manipulation. The permission could contribute to privilege escalation by allowing modification of the permissions associated with an IAM role.
Business / Security Impact	If abused by a compromised or unauthorized identity, the permission could allow additional privileges to be attached to an accessible IAM role. This could increase unauthorized access to AWS resources and affect the confidentiality and integrity of cloud assets.

Field	Content
Severity / Impact	Critical
Evidence Reference	PhaseC_analysis.json and aPhaseC_analysis.txt – Phase C IAM policy analysis

Finding 2: Wildcard Resource Scope in IAM Policy

Field	Content
Finding Title	Wildcard Resource Scope in IAM Policy
Type / Category	IAM Policy Gap / Excessive Permission / Access Control Weakness
Cloud Service / Resource	AWS IAM – privesc9-AttachRolePolicy
Description	The reviewed IAM policy grants iam:AttachRolePolicy with "Resource": "*". The wildcard resource scope means the permission is not restricted to specific approved IAM roles, resulting in broader access than necessary.
How Identified	The managed policy was identified through AWS CLI enumeration and exported using aws iam get-policy-version. The resulting policies.json file was manually reviewed to identify the wildcard resource scope.
MITRE ATT&CK Reference	T1098 – Account Manipulation. Excessive IAM permissions can support modification of account or role privileges.
Business / Security Impact	Wildcard scope increases the potential blast radius if the permission is misused or credentials are compromised. An attacker may be able to modify permissions across a broader set of IAM roles, increasing the risk of unauthorized access to AWS resources.
Severity / Impact	Critical
Evidence Reference	PhaseC_analysis.txt, and PhaseD_risk_matrix.xlsx

Finding 3: Privileged IAM Role Governance Gap

Field	Content
Finding Title	Privileged IAM Role Governance Gap
Type / Category	Access Control Weakness / IAM Governance Gap
Cloud Service / Resource	AWS IAM Roles / Identity Governance
Description	IAM enumeration identified multiple roles associated with privilege-escalation testing in the lab environment. IAM Access Analyzer was enabled to provide additional visibility and returned no external or cross-account findings. However, internal privileged roles and excessive permissions still require regular review because Access Analyzer findings alone do not represent a complete assessment of internal IAM privilege risk.
How Identified	IAM roles were enumerated using AWS CLI commands such as <code>aws iam list-roles</code> . IAM Access Analyzer was then configured and reviewed using <code>aws accessanalyzer list-analyzers</code> and <code>aws accessanalyzer list-findings</code> .
MITRE ATT&CK Reference	T1087.004 – Account Discovery: Cloud Account. IAM enumeration can reveal cloud identities and roles that may be relevant to further access or privilege analysis.
Business / Security Impact	Inadequate governance of privileged IAM roles can allow excessive or outdated permissions to remain unnoticed. If privileged access is compromised or misused, it could increase unauthorized access to AWS resources and affect the confidentiality and integrity of cloud assets.
Severity / Impact	High
Evidence Reference	PhaseD_risk_matrix.xlsx / PhaseD-AccessAnalyzer-Findings.png / IAM role enumeration screenshot

5.0 Risk Assessment & Cloud Threat Model

5.1 Cloud Security Control Gaps & Defensive Coverage

Finding / Gap	Observable / Trigger in Cloud Telemetry	Recommended Control	AWS Service / Tool for Implementation
Unrestricted IAM Policy Attachment Permission	AttachRolePolicy API activity, particularly when performed by an unexpected or non-administrative identity	Restrict iam:AttachRolePolicy to approved roles and policies; alert on sensitive IAM policy changes	AWS CloudTrail / EventBridge / CloudWatch / IAM
Wildcard Resource Scope in IAM Policy	IAM policy configuration containing sensitive permissions with Resource: "*"	Replace wildcard resources with specific role ARNs; enforce least privilege and review privileged policies	AWS IAM / IAM Access Analyzer / AWS Config
Privileged IAM Role Governance Gap	Creation or modification of privileged roles, trust policies, or policy attachments; unexpected role-assumption activity	Conduct periodic access reviews, remove unused roles, restrict trust relationships, and continuously monitor privileged IAM changes	IAM Access Analyzer / CloudTrail / AWS Config / Security Hub

5.2 Risk Exposure Over Time

Risk 1 — Unrestricted IAM Policy Attachment Permission

If the iam:AttachRolePolicy permission remains unrestricted, a compromised or misused identity could potentially attach highly privileged managed policies to accessible IAM roles. Over time, this could create persistent privilege-escalation opportunities and increase unauthorized access to AWS resources.

Risk 2 — Wildcard Resource Scope in IAM Policy

The identified "Resource": "*" scope increases the number of IAM resources potentially affected by the policy. If left unchanged, the broad permission scope increases the blast radius of credential compromise and makes enforcing least privilege more difficult.

Risk 3 — Privileged IAM Role Governance Gap

If privileged and test IAM roles are not periodically reviewed, unnecessary permissions or outdated roles may remain in the environment. Although Access Analyzer returned no external or cross-account findings during this assessment, internal excessive permissions could still remain unnoticed without continuous IAM policy, role, and trust-relationship reviews.

6.0 Recommendations

#	Finding	Specific Remediation Action	Priority	Standard / Reference
1	Unrestricted IAM Policy Attachment Permission	Restrict iam:AttachRolePolicy so it can only be used on specifically approved IAM roles. Review identities with this permission and remove it where it is not required. Monitor AttachRolePolicy activity through CloudTrail.	Immediate	ISO/IEC 27001 – Access Control / Least Privilege
2	Wildcard Resource Scope in IAM Policy	Replace "Resource": "*" in privesc9-AttachRolePolicy with specific approved IAM role ARNs. Apply least privilege so policy attachment permissions cannot affect unnecessary roles.	Immediate	ISO/IEC 27001 – Access Rights / Least Privilege
3	Privileged IAM Role Governance Gap	Perform scheduled reviews of privileged IAM roles, attached policies, and trust relationships. Remove unused lab/test roles and continue using IAM Access Analyzer to identify external or cross-account access.	Short-term / Ongoing	ISO/IEC 27001 – Identity Management / Access Rights Review

6.2 Strategic & Operational Improvements

- Establish regular IAM access reviews to identify unused roles, excessive permissions, outdated policies, and unnecessary trust relationships. Privileged IAM access should be reviewed on a scheduled basis.
- Enforce least privilege across IAM policies by restricting sensitive actions such as iam:AttachRolePolicy to approved roles and avoiding "Resource": "*" wherever resource-level restrictions are supported.
- Monitor high-risk IAM activity using AWS CloudTrail with EventBridge/CloudWatch alerts for sensitive actions such as AttachRolePolicy, role creation, policy changes, and trust-policy modifications.
- Continuously use IAM Access Analyzer to detect new external or cross-account access and review findings as part of routine cloud security monitoring.
- Introduce preventive IAM guardrails such as permission boundaries and, where AWS Organizations is used, Service Control Policies (SCPs) to reduce the possibility of privilege-escalation permissions being introduced across accounts.

7.0 Reflection

Q1 How would you communicate identified over-privileged roles to non-technical management?

I would explain that some IAM roles have more access than required, increasing the potential impact if an account is compromised. I would present the risk level, affected business resources, and recommend restricting permissions based on least privilege.

Q2 What business impact could result from an unmonitored cross-account trust relationship?

An unmonitored cross-account trust could allow an external or unintended AWS account to access company resources. This could lead to unauthorized access, data exposure, compliance issues, and financial or reputational damage.

Q3 How can automation improve continuous visibility into IAM configurations?

Automation can continuously identify changes to IAM roles, policies, permissions, and trust relationships instead of relying only on manual reviews. Tools such as IAM Access Analyzer, AWS Config, and CloudTrail can help security teams detect risky changes more quickly.

Q4 If you discovered an unused admin role in production, what remediation steps would you recommend?

I would first verify the role is truly unused by reviewing its purpose, owners, dependencies, and recent activity. After approval, I would remove or disable unnecessary privileged access and then delete the role while maintaining appropriate change and audit records.

8.0 Deliverables Submission Checklist

✓	Phase	Deliverable Description	Your Filename	Status
☐	Phase A	Theory evidence — e.g. architecture/relationship diagram, notes PDF, AI summary text file, annotated MITRE mapping	PhaseA-List -Users.png, PhaseA-List -Roles.png, PhaseA-List -Policies.png, phaseA_summary.txt	Complete
☐	Phase B	Environment setup evidence — e.g. VPC dashboard screenshot, CloudTrail config proof, IAM policy JSON, get-caller-identity output, tool version screenshots	PhaseB-CloudGoat-Deployed.png, PhaseB-IAM-Users.png, PhaseB-IAM-Roles.png, PhaseB_iam_entities.csv	Complete
☐	Phase C	Core execution evidence — e.g. CLI output log file, query results screenshot, policy test JSON, assume-role output, Athena query result, GuardDuty finding screenshot	PhaseC-IAM-Users.png PhaseC-IAM-Groups.png PhaseC-IAM-Policies.png PhaseC-Role-Trust-Policy.png PhaseC-Steampipe-Error.png PhaseC_policies.json PhaseC_analysis.txt	Complete
☐	Phase D	Extension & risk model evidence — e.g. hardened policy JSON, risk matrix XLSX/screenshot, threat model diagram, hosted lab completion badge, AI analysis summary	PhaseD_risk_matrix.xlsx, PhaseD-AccessAnalyzer-Findings.png	Complete
☐	Phase E	Hosted lab completion — e.g. TryHackMe badge screenshot, PwnedLabs completion proof, Cybr lab certificate (if required by your task brief)	PhaseC_Cybr_labs.png	One Completed
☐	Report	This report — exported as PDF using the naming convention below	CSE_CSE-AWS-L-007-04_S.K_20260819.pdf	Complete

9.0 Additional Observations

Several tool and configuration issues were encountered during the lab, which provided useful troubleshooting experience. **Steampipe** could not start its embedded PostgreSQL database, so AWS CLI was used as an alternative for IAM enumeration.

The **Policy Sentry** version installed in the environment did not support the required analyze command, so the exported IAM policy was reviewed manually and documented in analysis.txt. CloudGoat setup also required troubleshooting Terraform installation, AWS permissions, and configuration before the iam_privesc_by_attachment scenario was successfully deployed.

These challenges reinforced the importance of validating tool versions, IAM permissions, dependencies, and alternative methods when performing cloud security assessments.

Declaration & Sign-Off

I confirm that:

- All work in this report is my own except where AI usage is explicitly declared in Section 2.3.
- All technical activities were performed exclusively within the authorised cloud environments listed in Section 1.3.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed during this task.
- All AWS credentials, access keys, session tokens, and account identifiers used during this task have been redacted in evidence files before submission.
- I have reviewed this report for accuracy, completeness, and professional presentation before submission.

Intern Full Name	Signature	Date of Submission
Sukhmandeep Kaur	Sukhmandeep Kaur	19 – 08 - 2026